

THE JUNIOR GRC ANALYST HANDBOOK

**Governance, Risk and Compliance
from Zero**



GOVERNANCE



RISK



COMPLIANCE



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

GRC FROM ZERO

1. WHAT IS GRC?

GRC stands for Governance, Risk and Compliance.

It is a structured approach that helps organizations make the right decisions, manage risks and follow laws, regulations and internal policies.

2. WHY ORGANIZATIONS NEED GRC

- ✓ Protects people, data and assets
- ✓ Reduces the chance of costly mistakes
- ✓ Helps the business achieve its goals
- ✓ Ensures compliance with laws and regulations
- ✓ Builds trust with customers, partners and investors
- ✓ Supports safe and responsible growth

3. THE THREE PARTS OF GRC



GOVERNANCE

- Sets direction
- Defines policies and standards
- Allocates roles and responsibilities
- Ensures accountability
- Oversight and decision making



RISK

- Identifies what could go wrong
- Assess the likelihood and impact
- Decides how to treat risk
- Monitors changes in risk
- Helps the organization stay prepared



COMPLIANCE

- Ensures laws, regulations and internal policies are followed
- Verifies that required controls are in place
- Monitors ongoing adherence
- Prepares for audits
- Reduces legal and reputational risk

4. HOW GRC WORKS TOGETHER



Sets risk appetite and policies



Implements controls to manage risk



Provides risk insights for better decisions

Gives assurance that risks are being managed

5. WHERE A JUNIOR GRC ANALYST FITS



As a junior GRC analyst, you support the GRC team by:

- Collecting and organizing evidence
- Maintaining risk and control registers
- Supporting policy and compliance reviews
- Preparing documents for audits
- Tracking issues and remediation actions
- Learning and growing into more complex GRC tasks

KEY TAKEAWAY

- ✓ Governance sets the direction.
- ✓ Risk helps you understand what could go wrong.
- ✓ Compliance ensures the rules are followed.
- ✓ GRC works together to keep the organization safe, compliant and successful.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

GOVERNANCE

WHO DECIDES WHAT?

Policies, standards, procedures, guidelines, ownership, accountability, approval and oversight.

1. WHAT IS GOVERNANCE?



Governance is the system of rules, roles and decision-making that directs and controls how an organization operates. It ensures the organization achieves its goals, manages risks and complies with laws, regulations and internal policies.

2. WHY GOVERNANCE MATTERS?

- ✓ Provides clear direction and decision-making
- ✓ Defines who is responsible
- ✓ Ensures consistent practices across the organization
- ✓ Reduces the risk of fraud, errors and non-compliance
- ✓ Supports business goals and growth
- ✓ Builds trust with customers, regulators and investors

3. KEY GOVERNANCE DOCUMENTS



POLICY

- High-level rules
- Defines what must be done
- Approved by senior management
- Applies to the entire organization



STANDARD

- Sets mandatory requirements
- Explains how to meet the policy
- More detailed than a policy
- Owned by a specific team or function



PROCEDURE

- Step-by-step instructions
- Explains who does what
- Often includes process flows
- Used by teams in daily work



GUIDELINE

- Recommended best practices
- Provides guidance on how to achieve the standard
- May be optional
- Helps improve consistency



EVIDENCE

- Shows the rule was followed
- Examples: logs, screenshots, approvals, reports
- Used for audits and assurance

4. ROLES AND DECISION-MAKING

ROLE	RESPONSIBILITY
Board / Executive	Sets strategic direction and appetite for risk
GRC / Risk Team	Develops and maintains policies and governance frameworks
Business Owners	Own and implement policies and controls in their areas
Management	Approves decisions and ensures accountability
Employees	Follow policies, standards and procedures

5. KEY GOVERNANCE CONCEPTS



OWNERSHIP

Clearly defined person or team responsible for a policy, control or process.



ACCOUNTABILITY

Being answerable for decisions, actions and outcomes.



APPROVAL

Formal sign-off before a policy, change or risk decision is accepted.



OVERSIGHT

Ongoing monitoring to ensure policies and controls are effective and continue to be followed.

6. JUNIOR GRC ANALYST INSIGHT



- Understand who owns each policy and control.
- Know the approval chain for key decisions.
- Learn where to find the latest versions of policies, standards and procedures.
- Check review dates and help track updates.
- Ask questions when documents are unclear.
- Always keep evidence organized and easy to find.

7. KEY TAKEAWAY



- ✓ Governance sets the direction. Policies, standards, procedures and guidelines work together.
- ✓ Clear ownership and accountability reduce risk.
- ✓ Approval and oversight ensure the rules are followed.
- ✓ As a junior analyst, you support this by keeping documents, evidence and records organized and up to date.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

RISK

WHAT COULD GO WRONG?

Assets, threats, vulnerabilities, likelihood, impact, risk events, and basic risk thinking.

1. WHAT IS RISK?



Risk is the possibility that something could happen and have a negative impact on the organization's goals, people, assets, operations or reputation.

2. KEY TERMS



Asset

Something of value (e.g. data, systems, people, reputation).



Threat

Anything that could cause harm (e.g. hacker, error, natural disaster).



Vulnerability

A weakness that can be exploited (e.g. unpatched system, weak password).



Risk Event

When a threat exploits a vulnerability and causes an impact.

3. SIMPLE RISK EXAMPLE



THREAT
Hacker



VULNERABILITY
Unpatched system



RISK EVENT

System is compromised



IMPACT

Data is lost and service is unavailable

4. LIKELIHOOD AND IMPACT

LIKELIHOOD



How likely is it to happen?

- Very Low
- Low
- Medium
- High
- Very High

IMPACT



How serious would the impact be?

- Negligible
- Minor
- Moderate
- Major
- Severe

5. RISK RATING

Severe	M	H	H	H	H
Major	M	M	H	H	H
Moderate	L	M	M	H	H
Minor	L	L	M	M	H
Negligible	L	L	L	M	M
	Very Low	Low	Medium	High	Very High
	Likelihood				

6. TYPES OF RISKS



Strategic Risk
Affects business goals and long-term success.



Operational Risk
Affects day-to-day operations (e.g. system failure, human error).



Financial Risk
Affects financial stability (e.g. fraud, cost overruns).



Compliance Risk
Breach of laws, regulations or internal policies.



Reputational Risk
Harms trust and public image (e.g. data breach, service outage).

7. BASIC RISK THINKING



- Understand what assets are important.
- Identify what could go wrong.
- Consider how likely it is to happen.
- Consider how serious the impact would be.
- Decide how to treat and manage the risk.
- Monitor and review the risk regularly.

8. COMMON RISK EVENTS



- Data breach
- System outage
- Loss of key personnel
- Natural disaster
- Cyber attack (ransomware)
- Human error
- Fraud or theft
- Supplier failure
- Non-compliance with regulation

9. KEY TAKEAWAY



- ✓ Risk is the possibility of a negative event.
- ✓ It involves assets, threats and vulnerabilities.
- ✓ You assess the likelihood and impact to understand how serious the risk is.
- ✓ Risk events can affect people, operations, finances, compliance and reputation.
- ✓ Good risk thinking helps the organization make better decisions.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

THE RISK LIFECYCLE

Identify → Assess → Treat → Monitor → Report

Shows how a risk moves from discovery to ongoing monitoring.

1. WHAT IS THE RISK LIFECYCLE?

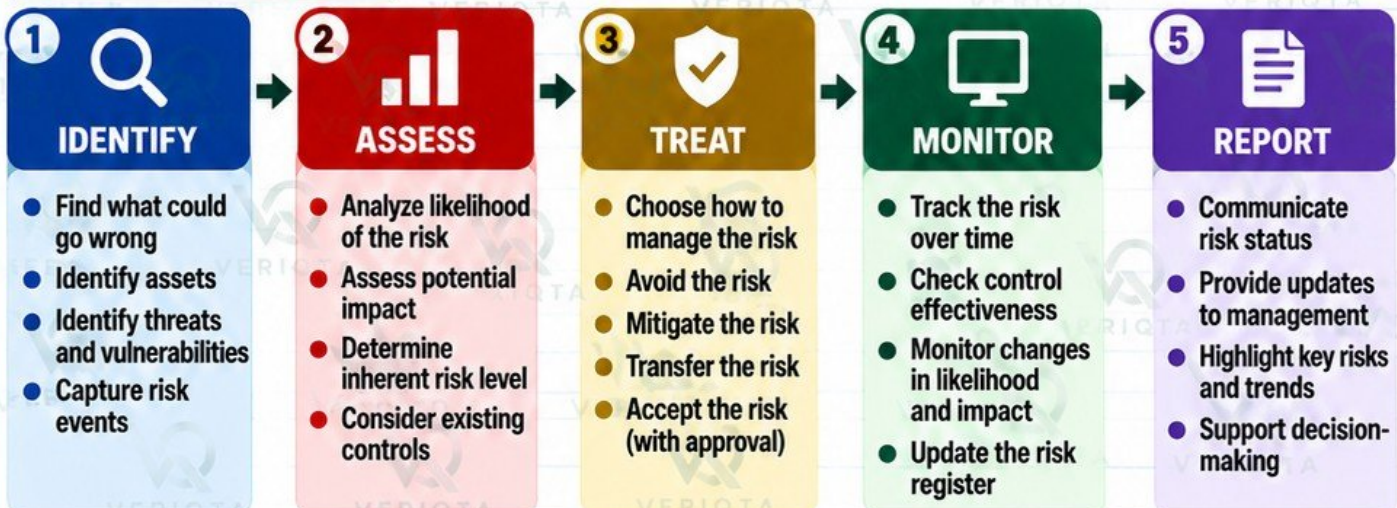


The risk lifecycle is a step-by-step process organizations use to find, understand, manage and keep track of risks over time.

2. WHY IT MATTERS

- ✓ Helps the organization stay prepared
- ✓ Reduces surprises and costly losses
- ✓ Ensures risks are properly managed
- ✓ Supports informed business decisions
- ✓ Keeps risks under continuous review

3. THE FIVE STAGES



4. HOW A RISK MOVES THROUGH THE LIFECYCLE



5. ROLES INVOLVED

ROLE	RESPONSIBILITY
Business Owner	Identifies risks in their area and helps manage them.
Risk Team / GRC	Facilitates the risk process and maintains the register.
Management	Makes decisions on risk treatment and approves risk acceptance.
Control Owners	Implement and operate controls to reduce risk.
Internal Audit	Provides independent assurance on the risk process.

6. KEY TAKEAWAYS



- ✓ Risk is a continuous process, not a one-time activity.
- ✓ Each stage is important.
- ✓ Risks can change over time.
- ✓ Good documentation makes the process effective.
- ✓ A junior GRC analyst supports each stage with data, coordination and tracking.

INHERENT vs RESIDUAL RISK

Risk before controls versus risk after controls, with a simple business example and the role of control effectiveness.

1. WHAT IS INHERENT RISK?



- The level of risk before any controls are implemented.
- It shows the natural level of risk if nothing is done to reduce it.
- Based on the asset, threat, vulnerability, likelihood and impact.

2. WHAT IS RESIDUAL RISK?



- The level of risk after controls are implemented.
- It reflects the remaining risk once controls are in place.
- It depends on how effective the controls are.

3. SIMPLE BUSINESS EXAMPLE

Asset:	Customer data
Threat:	External hacker
Vulnerability:	Unpatched system
Risk Event:	Data breach
Impact:	Financial loss, legal penalties, reputation damage

INHERENT RISK (BEFORE CONTROLS)

Likelihood	High
Impact	High
Risk Level	High

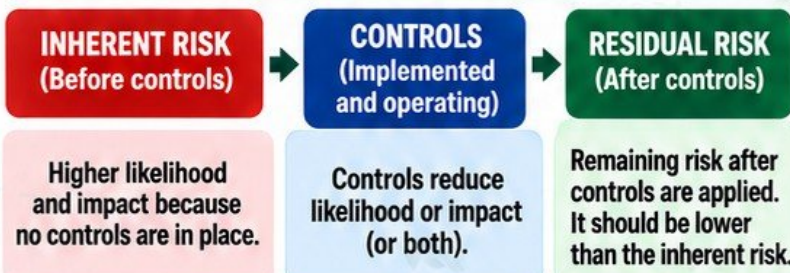
Implement Controls

- Patch management
- Firewall
- Access controls
- Monitoring
- Security awareness

RESIDUAL RISK (AFTER CONTROLS)

Likelihood	Low
Impact	High
Risk Level	Medium

4. HOW CONTROLS REDUCE RISK



5. ROLE OF CONTROL EFFECTIVENESS

Control Effectiveness	Impact on Residual Risk
Effective	Significantly reduces risk
Partially Effective	Reduces risk, but some risk remains
Ineffective	Little to no reduction in risk

6. EXAMPLE RISK ASSESSMENT

Scenario	Likelihood	Impact	Inherent Risk	Key Controls	Residual Risk
Customer data on unpatched server	High	High	High	• Patching • Firewall • Monitoring • Access control	Medium
Employee fails for phishing email	Medium	High	High	• Security training • Email filtering • MFA	Low

7. KEY TAKEAWAYS



- ✓ Inherent risk is the risk level before any controls.
- ✓ Residual risk is the remaining risk after controls.
- ✓ Controls reduce either likelihood, impact, or both.
- ✓ The more effective the controls, the lower the residual risk.
- ✓ Residual risk should always be lower than inherent risk.
- ✓ Organizations decide if the residual risk is acceptable.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

RISK TREATMENT

Avoid, mitigate, transfer, and accept. Explains who can accept risk and why analysts should not make that decision themselves.

1. WHAT IS RISK TREATMENT?



- Risk treatment is the process of choosing and implementing action to manage a risk.
- The goal is to reduce risk to an acceptable level.
- Not all risks can be eliminated, but they can be managed.
- The chosen treatment should align with the organization's goals, resources and risk appetite.

2. THE FOUR RISK TREATMENT OPTIONS

AVOID



- Stop the activity that creates the risk.
- Eliminate the risk completely.
- Used when the risk is too high or not worth taking.

MITIGATE



- Reduce the likelihood or impact of the risk.
- Implement controls.
- Most common option.
- Does not eliminate the risk, but lowers it to an acceptable level.

TRANSFER



- Shift the risk to a third party (e.g. insurance or contract).
- The risk still exists but the financial or operational impact is shared with another party.

ACCEPT



- Acknowledge the risk and take no further action (beyond monitoring).
- Used when the risk is within the organization's risk appetite.
- Must be formally approved.

3. WHEN TO USE EACH OPTION

Option	Typical Use Case	Example
Avoid	Risk is too high or does not align with goals.	Do not store sensitive data in a high-risk country.
Mitigate	Risk can be reduced with controls.	Implement multi-factor authentication.
Transfer	Risk can be shared with a third party.	Buy cyber insurance.
Accept	Residual risk is low and within risk appetite.	Accept minor risk for low-value systems.

4. WHO CAN ACCEPT RISK?

Executive Management	Often approves significant risks that align with business goals and risk appetite.
Risk Committee (When applicable)	Reviews and approves medium to high risks.
Business Owner	May approve low-level risks within their area, depending on the organization's policy.
Board of Directors (For major risks)	Approves high-impact risks that could affect the entire organization.

5. RISK TREATMENT PROCESS



6. WHY ANALYSTS SHOULD NOT ACCEPT RISK



- Risk acceptance is a business decision.
- Analysts provide risk information and recommendations, but they do not have the authority to accept risk.
- Accepting risk without proper approval can lead to non-compliance, financial loss and reputational damage.
- Only authorized roles (e.g. management, risk committee or board) can formally accept risk.

7. KEY CONSIDERATIONS



- ✓ Choose the treatment that best aligns with the organization's goals.
- ✓ Consider cost, resources and feasibility.
- ✓ Ensure the treatment reduces the risk to an acceptable level.
- ✓ Document the decision and approval.
- ✓ Review the risk regularly to ensure the treatment is still effective.

8. KEY TAKEAWAY



- ✓ Risk treatment helps manage risk to an acceptable level.
- ✓ Avoid, mitigate, transfer and accept are the four options.
- ✓ Risk acceptance is a management decision, not a junior analyst's decision.
- ✓ Analysts support the process by providing analysis, recommendations and evidence.

THE RISK REGISTER

How to read and maintain a practical risk register, including owner, likelihood, impact, controls, treatment, status, and due date.

1. WHAT IS A RISK REGISTER?



- A central list of identified risks.
- Shows key details about each risk and how it will be managed.
- Helps the organization track, prioritize and reduce risk.
- Updated regularly as new risks emerge or existing risks change.

2. KEY COLUMNS AND WHAT THEY MEAN

Risk ID	Unique number for each risk.
Risk Description	Clear and short explanation of the risk.
Owner	Person responsible for managing the risk.
Likelihood	How likely the risk is to happen.
Impact	How serious the impact would be.
Inherent Risk	Risk level before controls.
Existing Controls	Current controls in place.
Risk Treatment	Avoid, mitigate, transfer or accept.
Residual Risk	Risk level after controls.
Status	Open, In Progress, Closed, On Hold.
Due Date	Target date for action or review.

3. LIKELIHOOD AND IMPACT SCALE (EXAMPLE)

Likelihood		Impact	
Level	Description	Level	Description
1 - Very Low	Rarely happens	1 - Very Low	Minimal impact
2 - Low	Unlikely to happen	2 - Low	Minor impact
3 - Medium	Possible	3 - Medium	Moderate impact
4 - High	Likely to happen	4 - High	Major impact
5 - Very High	Almost certain	5 - Very High	Severe impact

4. EXAMPLE RISK REGISTER

Risk ID	Risk Description	Owner	Likelihood	Impact	Inherent Risk	Existing Controls	Risk Treatment	Residual Risk	Status	Due Date
R-001	Unauthorized access to customer data	IT Manager	4 (High)	5 (Very High)	High	MFA, access reviews	Mitigate	Medium	In Progress	30 Nov 2026
R-002	System outage affecting operations	Operations Manager	3 (Medium)	4 (High)	High	Redundancy, backups	Mitigate	Medium	Open	15 Dec 2026
R-003	Third-party vendor data breach	Procurement Manager	3 (Medium)	5 (Very High)	High	Vendor due diligence, contracts	Transfer	Medium	In Progress	31 Jan 2027
R-004	Non-compliance with data protection regulation	Compliance Manager	2 (Low)	4 (High)	Medium	Policies, training, monitoring	Mitigate	Low	Open	28 Feb 2027

5. HOW TO MAINTAIN THE RISK REGISTER

- 1 Identify new risks from audits, incidents, projects and changes.
- 2 Assess likelihood and impact to determine the inherent risk.
- 3 Document existing controls.
- 4 Decide the risk treatment (avoid, mitigate, transfer or accept).
- 5 Assign an owner, set a due date and track progress.
- 6 Review and update the register regularly.

6. GOOD PRACTICES

- ✓ Keep descriptions clear and specific.
- ✓ Use consistent likelihood and impact scales.
- ✓ Assign a single accountable owner.
- ✓ Record existing controls and planned actions.
- ✓ Update the register when things change.
- ✓ Review with key stakeholders regularly.
- ✓ Keep a history of changes.

7. KEY TAKEAWAYS



- ✓ A risk register helps organizations track and manage risks.
- ✓ It includes key details such as owner, likelihood, impact, controls, treatment, status and due date.
- ✓ It should be reviewed and updated regularly.
- ✓ Good risk registers support better decision-making and reduce surprises.

CONTROLS FROM ZERO

What a control is and how preventive, detective, corrective, manual, automated, technical, and administrative controls differ.

1. WHAT IS A CONTROL?



- A control is a measure put in place to reduce risk.
- It helps prevent, detect, or correct unwanted events.
- Controls reduce the likelihood or impact of a risk to an acceptable level.
- Controls can be people, processes, technology or a combination.

2. WHY CONTROLS ARE IMPORTANT?



- Protects assets and information
- Reduces the likelihood of risks materializing
- Limits the impact if risks occur
- Supports compliance with laws, regulations and frameworks
- Builds trust with customers, partners and stakeholders

3. TYPES OF CONTROLS (BY PURPOSE)

PREVENTIVE CONTROLS



- Stop a risk from happening.
- Reduce the likelihood of an event.
- **Examples:** access controls, multi-factor authentication, approval processes, firewalls.

DETECTIVE CONTROLS



- Identify when a risk has happened.
- Detect and alert on unusual activity.
- **Examples:** log monitoring, intrusion detection systems, security alerts, audit logs.

CORRECTIVE CONTROLS



- Fix the issue after it has happened.
- Restore normal operations and reduce the impact.
- **Examples:** incident response procedures, backups and recovery, patching, account disabling.

4. TYPES OF CONTROLS (BY IMPLEMENTATION)

MANUAL CONTROLS



- Performed by a person.
- Relies on human judgment and action.
- **Examples:** management review, manual approval, checklist, physical inspection.

AUTOMATED CONTROLS



- Performed by a system or technology.
- Runs automatically based on defined rules.
- **Examples:** automated access revocation, system alerts, automated backups.

5. TYPES OF CONTROLS (BY NATURE)

TECHNICAL CONTROLS



- Implemented using technology.
- **Examples:** firewalls, endpoint protection, encryption, access controls, logging, monitoring tools.

ADMINISTRATIVE CONTROLS



- Implemented through policies, procedures and guidelines.
- **Examples:** security policy, acceptable use policy, training, risk assessments, vendor management processes.

6. CONTROL EXAMPLES

Control Type	Example	Purpose
Preventive	Multi-factor authentication	Stop unauthorized access
Detective	Log monitoring	Identify suspicious activity
Corrective	Backup and recovery	Restore systems after a failure
Manual	Management review	Human oversight
Automated	Automated account disabling	Automatically remove access
Technical	Firewall	Block unauthorized traffic
Administrative	Security policy	Define rules and expectations

7. KEY TAKEAWAYS



- ✓ A control reduces risk.
- ✓ Controls can prevent, detect or correct issues.
- ✓ Controls can be manual or automated.
- ✓ Controls can be technical or administrative.
- ✓ Different control types work together.
- ✓ Choose the right control based on the risk, the environment and the objective.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

CONTROL DESIGN VS OPERATING EFFECTIVENESS

“Is the control designed correctly?” versus “Did it actually operate?”
with a practical access-review example.

1. CONTROL DESIGN EFFECTIVENESS



- Answers the question: “Is the control designed correctly?”
- Evaluates whether the control, if followed, would prevent, detect or correct the risk.
- Looks at the design, not whether it actually ran.
- **Example:** Is there a formal access review policy with clear frequency, owners, and approval process?

2. OPERATING EFFECTIVENESS



- Answers the question: “Did the control actually operate?”
- Evaluates whether the control was performed as designed, consistently and on time.
- Looks at evidence of performance.
- **Example:** Were access reviews actually completed, approvals obtained, and inappropriate access removed?

3. KEY DIFFERENCES

Aspect	Control Design Effectiveness	Operating Effectiveness
Key Question	Is the control designed correctly?	Did the control actually operate?
Focus	Design, structure and intent	Performance and execution
What is Reviewed?	Policies, procedures, control activities, roles and responsibilities	Actual evidence, records and implementation
Typical Evidence	Policy document, process flow, control description, RACI, system configuration	Completed records, logs, reports, approvals, timestamps
Outcome	Design is appropriate or needs improvement	Operating effectively or operating with gaps

4. PRACTICAL EXAMPLE: USER ACCESS REVIEW

CONTROL DESIGN EFFECTIVENESS

Design Question: Is the access review control designed correctly?



- There is a documented access review policy.
- Scope includes all critical systems.
- Frequency is defined (e.g., quarterly).
- Clear owners (system owners and reviewers) are assigned.
- The process includes review, approval and removal of inappropriate access.
- Roles and responsibilities are defined.

If all of the above are in place, the control is well designed.

OPERATING EFFECTIVENESS

Operating Question: Did the access review actually operate?



- Access reviews were completed for the period (e.g., Q1 2026).
- Evidence exists (review reports, approval records).
- Reviews were performed on time.
- Inappropriate or unnecessary access was removed.
- There is evidence of management approval.
- Issues were tracked and remediated.

If the above activities were performed as designed, the control is operating effectively.

5. COMMON ISSUES



- Control is not clearly defined.
- Policy exists but is not followed.
- Reviews are completed late.
- Approvals are missing.
- Inappropriate access is not removed.
- Evidence is incomplete or not retained.

6. WHY BOTH MATTER



- A well-designed control that does not operate does not reduce risk.
- A control can operate but still be poorly designed.
- Both design and operating effectiveness are needed for real risk reduction.

7. KEY TAKEAWAYS



- Design answers “Should this control work?”
- Operating effectiveness answers “Did it work?”
- For access reviews, check both the design and the actual execution.
- Use real evidence to support your assessment.

EVIDENCE, PROVE THE CONTROL WORKED

What counts as evidence, evidence quality, screenshots, logs, tickets, approvals, timestamps, populations, samples, and common weak evidence.

1. WHAT IS EVIDENCE?



- Evidence is proof that a control is designed and operating effectively.
- It shows that the control actually happened, not just that it exists.
- Evidence can be documents, records, system data, screenshots or other verifiable information.

2. WHY EVIDENCE IS IMPORTANT



- Confirms the control is working.
- Supports audit, compliance and regulatory requirements.
- Helps identify gaps and improve processes.
- Provides a reliable basis for decision-making.

3. GOOD EVIDENCE QUALITIES

✓ Relevant	Directly related to the control.
🛡️ Reliable	From a trustworthy source.
⚙️ Complete	Covers all key details.
★ Accurate	Correct and error-free.
🕒 Timely	From the correct time period.
≡ Verifiable	Can be validated by someone else.

4. COMMON TYPES OF EVIDENCE (WITH EXAMPLES)

SCREENSHOTS	LOGS	TICKETS	APPROVALS	TIMESTAMPS	REPORTS
● System settings. ● User access lists. ● Configuration pages.	● System logs. ● Audit logs. ● Security event logs.	● Change tickets. ● Access request tickets. ● Incident tickets.	● Management approvals. ● Risk acceptance. ● Policy exceptions.	● Date and time of action. ● Shows when the control was performed.	● Access review reports. ● Compliance reports. ● System generated reports.

5. POPULATION vs SAMPLE

POPULATION	SAMPLE
● The total number of items you are checking. ● Example: All 1,200 user accounts in the system.	● A smaller number of items selected from the population. ● Example: 50 user accounts chosen for review. ● The sample should be representative and selected using a clear method.

6. PRACTICAL EXAMPLE: ACCESS REVIEW EVIDENCE

Control:	Quarterly review of user access for critical systems.
Evidence Type:	Access review report, approvals, system logs, tickets.
What to Look For:	● List of users reviewed. ● Date of review. ● Approvals from system owner/manager. ● Evidence of removed inappropriate access. ● Timestamps showing when the review was completed.
Good Evidence:	Report showing all users, approval emails, screenshots of removed access, and system logs.
Weak Evidence:	A single screenshot without date, no approval, or incomplete user list.

7. COMMON WEAK EVIDENCE



- Screenshots without visible date or username.
- Evidence that is incomplete or missing key details.
- No approval or unclear who approved.
- Evidence not related to the control.
- Old evidence not from the review period.
- Edited or unclear screenshots.
- No supporting logs or records.
- Verbal confirmation without documentation.

8. TIPS FOR COLLECTING GOOD EVIDENCE



- ✓ Always capture the date, time and username.
- ✓ Make sure the evidence covers the full population or a valid sample.
- ✓ Include approvals and supporting documents.
- ✓ Keep evidence organized and labeled.
- ✓ Use system-generated reports where possible.
- ✓ Verify that the evidence matches the control requirement.
- ✓ Review evidence for completeness and clarity before submitting.

9. KEY TAKEAWAYS

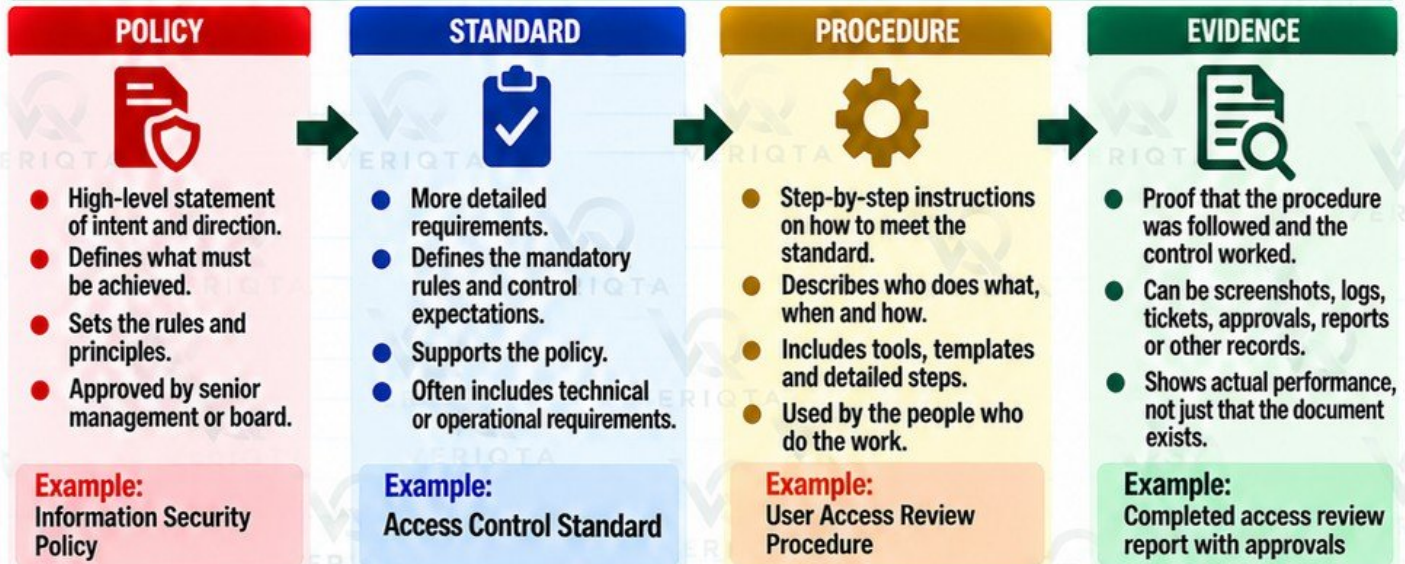


- ✓ Evidence proves the control worked.
- ✓ Good evidence is relevant, reliable, complete, accurate, timely and verifiable.
- ✓ Use the right type of evidence.
- ✓ Understand the difference between population and sample.
- ✓ Avoid common weak evidence.
- ✓ Proper evidence supports a successful audit and reduces risk.

POLICIES, STANDARDS AND PROCEDURES

How governance documents relate: Policy → Standard → Procedure → Evidence.
Includes document ownership and review cycles.

1. HOW THEY RELATE



2. KEY DIFFERENCES

Aspect	Policy	Standard	Procedure	Evidence
Purpose	Sets direction and intent.	Defines requirements.	Explains how to do it.	Proves it was done.
Level	High-level	Detailed requirements	Step-by-step instructions	Actual records
Audience	Executives, management, all staff	IT, security, process owners	End users, operational teams	Auditors, management, regulators
Language	Principles and rules	Mandatory requirements	Action steps	Factual records
Example	Information Security Policy	Password Standard	Password Reset Procedure	Password reset ticket with approval

3. DOCUMENT OWNERSHIP

Document Type	Typical Owner
Policy	Senior Management, Board or Policy Committee
Standard	Functional Owner (e.g., CISO, IT, Compliance)
Procedure	Process Owner or Operational Team
Evidence	Process Owner (Generated by system or team)

4. TYPICAL REVIEW CYCLES

Document Type	Typical Review Frequency	Who Reviews	Trigger for Early Review
Policy	Every 2-3 years	Policy Owner, Senior Management	Major business change, new regulation, significant risk
Standard	Every 1-2 years	Functional Owner, Subject Matter Experts	Technology change, new threats, audit findings
Procedure	Every 1-2 years (or sooner)	Process Owner, Operational Team	Process change, system change, issues or incidents
Evidence	Ongoing (continuous)	Process Owner, Auditors (during review)	Regular monitoring, control testing, audits

6. COMMON MISTAKES

- Policies that are too detailed.
- Standards that are unclear or not measurable.
- Procedures that are outdated or not followed.
- No document owner.
- Documents not reviewed regularly.
- Missing or weak evidence.

7. KEY TAKEAWAYS

- ✓ Policy sets the direction.
- ✓ Standard defines the requirements.
- ✓ Procedure explains how to do it.
- ✓ Evidence proves it was done.
- ✓ Each document has a clear owner.
- ✓ Review documents regularly.
- ✓ Keep everything aligned and up to date.

5. GOOD PRACTICES

- ✓ Keep documents clear, simple and practical.
- ✓ Ensure each document has a named owner.
- ✓ Set and follow a regular review cycle.
- ✓ Update documents when there are changes in risks, regulations or technology.
- ✓ Make sure procedures align with standards and policies.
- ✓ Maintain good quality evidence to show the control works.

FRAMEWORKS WITHOUT THE CONFUSION

Beginner introduction to NIST CSF, ISO/IEC 27001, SOC 2, COBIT, CIS Controls, PCI DSS, and how frameworks differ from laws and regulations.

1. KEY FRAMEWORKS OVERVIEW

NIST CSF	ISO/IEC 27001	SOC 2	COBIT	CIS CONTROLS	PCI DSS
 ● Risk-based framework to improve cybersecurity posture. ● 5 core functions: Identify, Protect, Detect, Respond, Recover. ● Flexible and widely used across industries. Best For: All organizations (starting point).	 ● International standard for Information Security Management System (ISMS). ● Provides requirements to establish, implement, maintain and continually improve security. Best For: Organizations seeking certification and a full ISMS.	 ● Audit framework for service organizations. ● Focuses on 5 trust services criteria: Security, Availability, Processing Integrity, Confidentiality, Privacy. ● Results in an audit report (not a certification). Best For: SaaS, cloud and service organizations.	 ● IT governance framework. ● Aligns IT with business goals. ● Focus on governance, management, performance and compliance. Best For: Organizations that need strong IT governance and oversight.	 ● Set of prioritized security controls. ● 20 critical controls to reduce common cyber risks. ● Practical and implementation focused. Best For: Organizations that want a simple, practical and actionable control set.	 ● Security standard for payment card data. ● 12 main requirements to protect cardholder data. ● Mandatory for organizations that store, process or transmit payment card information. Best For: Retailers, e-commerce and any organization handling card payments.

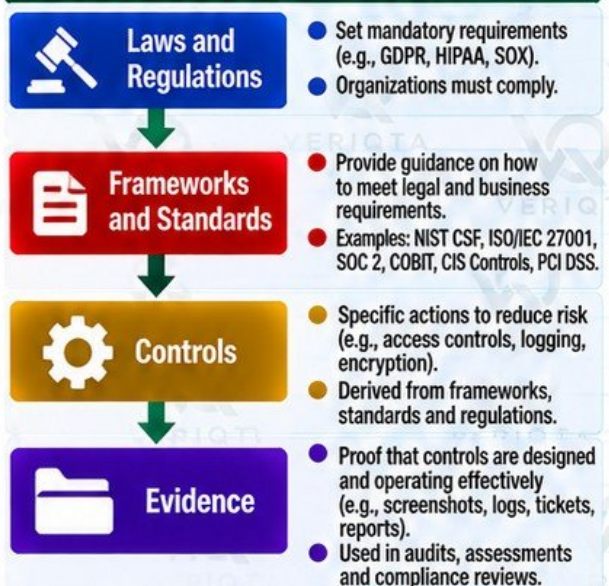
2. FRAMEWORKS vs LAWS AND REGULATIONS

Aspect	Frameworks	Laws and Regulations
What they are	Guidance and best practices.	Legally enforceable requirements.
Purpose	Help organizations improve security, governance and risk management.	Set mandatory rules that must be followed.
Examples	NIST CSF, ISO/IEC 27001, SOC 2, COBIT, CIS Controls, PCI DSS.	GDPR, HIPAA, SOX, PCI DSS (also a standard and a contractual requirement), local data protection laws.
Mandatory?	Generally voluntary (except when contractually required).	Mandatory (enforced by government or regulatory bodies).
Outcome	Improved security, better governance, audit readiness.	Legal compliance, avoids fines and penalties.

4. QUICK COMPARISON TABLE

Framework	Focus Area	Type	Outcome
NIST CSF	Cybersecurity risk management	Framework	Improved security posture
ISO/IEC 27001	Information security management	Standard	Certification (ISO 27001)
SOC 2	Service organization controls	Framework	Audit report
COBIT	IT governance and management	Framework	Better IT governance
CIS Controls	Practical security controls	Framework	Reduced cyber risk
PCI DSS	Payment card data security	Standard	Compliance with PCI requirements

3. HOW THEY ALL FIT TOGETHER



5. KEY TAKEAWAYS

- ✓ Frameworks provide guidance, laws set mandatory rules.
- ✓ Different frameworks have different objectives.
- ✓ Organizations can use multiple frameworks together.
- ✓ The right framework depends on your industry, risks and business goals.
- ✓ Evidence is needed to show that controls are working.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

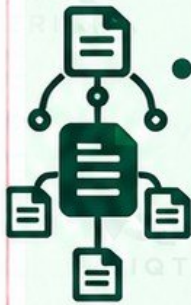


@veriqta

CONTROL MAPPING

How one control can support several requirements. Introduces control libraries, framework mappings, and avoiding duplicate work.

1. WHAT IS CONTROL MAPPING?



- Links one control to multiple requirements across different frameworks.
- Shows how the same control helps you meet several compliance and governance requirements.
- Reduces duplicate work, saves time and makes compliance more efficient.

2. WHY IT IS IMPORTANT



- Avoids doing the same work multiple times.
- Provides a complete view of control coverage.
- Helps with audit readiness.
- Supports multiple frameworks (e.g., NIST, ISO 27001, SOC 2, PCI DSS).
- Improves consistency and reduces gaps.

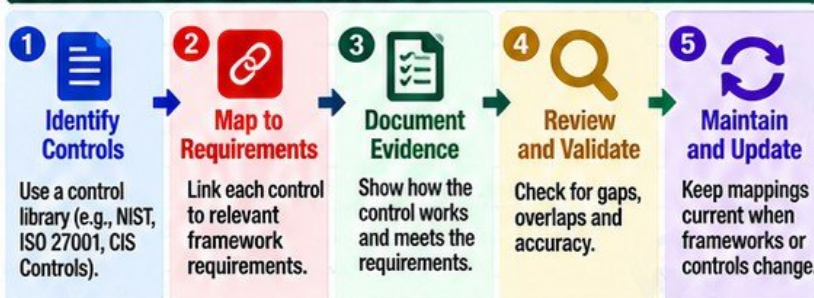
3. KEY TERMS

Control Library	A collection of standard controls (e.g., NIST, ISO 27001, CIS Controls).
Mapping	Linking a control to one or more framework requirements.
Requirement	A specific rule or expectation from a framework, law or regulation.
Crosswalk	A table that shows how requirements from different frameworks align.
Many-to-Many	One control can map to several requirements, and one requirement can be supported by several controls.

4. PRACTICAL EXAMPLE: ONE CONTROL, MULTIPLE FRAMEWORK REQUIREMENTS

Control	Description	NIST CSF	ISO/IEC 27001	SOC 2	CIS Controls	PCI DSS
Access Review (AC-01)	Regularly review user access to ensure it is appropriate and remove unnecessary access.	PR.AC-1 Manage identities and access.	A.9.2.6 Review of user access rights.	CC6.1 Logical access security.	Control 6 Access Control Management.	8.4.1 Review user access at least quarterly.
Multi-Factor Authentication (AC-02)	Require MFA for all privileged and remote access.	PR.AC-7 Protective technology.	A.9.4.2 Secure log-on procedures.	CC6.6 Logical access controls.	Control 6 Access Control Management.	8.3.1 Use MFA for remote access.
Security Logging (AC-03)	Enable and monitor logs for critical systems.	DE.CM-1 Monitor network activity.	A.8.15.1 Logging and monitoring.	CC7.2 System monitoring.	Control 8 Audit Log Management.	10.2.1 Log all access to cardholder data.

5. CONTROL MAPPING PROCESS



6. EXAMPLE: FRAMEWORK CROSSWALK

Control ID	Control	NIST CSF	ISO 27001	SOC 2	CIS	PCI DSS
AC-01	Access Review	✓	✓	✓	✓	✓
AC-02	MFA	✓	✓	✓	✓	✓
AC-03	Logging	✓	✓	✓	✓	✓
AC-04	Patch Management	✓	✓	✓	✓	✓
AC-05	Vulnerability Scanning	✓	✓	✓	✓	✓

7. BEST PRACTICES



- Use recognized control libraries.
- Map controls once and reuse across frameworks.
- Keep evidence linked to the control, not each framework.
- Review mappings regularly.
- Maintain version control for your mapping documents.
- Work with stakeholders (IT, Security, Compliance, Audit).

8. COMMON MISTAKES



- Mapping the same control multiple times unnecessarily.
- Using outdated framework versions.
- No clear evidence for the control.
- Ignoring framework differences.
- Not reviewing mappings when controls change.

9. KEY TAKEAWAYS



- One control can support multiple framework requirements.
- Control mapping reduces duplicate work and saves time.
- Use control libraries and crosswalks to simplify mapping.
- Keep mappings and evidence up to date.
- It helps you stay audit-ready and improves compliance.

ACCESS CONTROL AND IAM

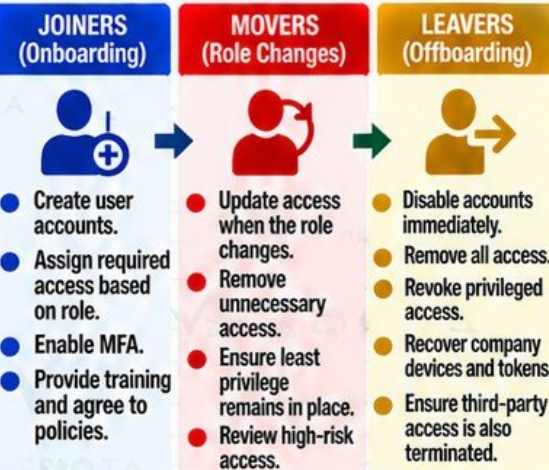
Joiners, movers, leavers, least privilege, privileged access, MFA, access reviews, segregation of duties, and evidence a GRC analyst may request.

1. WHAT IS ACCESS CONTROL AND IAM?



- Access control ensures the right people have the right access to the right resources at the right time.
- IAM (Identity and Access Management) manages identities, authentication and authorisation.
- Helps protect data, systems and business operations.
- A key focus area in GRC audits and compliance assessments.

2. THE IDENTITY LIFECYCLE



3. LEAST PRIVILEGE



- Users should only have the minimum access needed to perform their job.
- Reduces the risk of accidental or malicious activity.
- Access should be reviewed regularly to remove excess rights.

4. PRIVILEGED ACCESS



- Includes admin, root, service and other high-risk accounts.
- Must be strictly controlled, monitored and approved.
- Use privileged access management (PAM) tools where possible.
- Requires stronger controls such as MFA, justification and session recording.

5. MULTI-FACTOR AUTHENTICATION (MFA)



- Requires two or more forms of verification (e.g., password + code).
- Significantly reduces the risk of unauthorized access.
- Should be enabled for all users, especially privileged accounts.
- GRC analysts will check MFA policy, coverage and evidence of enforcement.

6. ACCESS REVIEWS



- Regularly review user access to ensure it is still needed.
- Confirm that users have appropriate access for their current role.
- Remove excessive or unnecessary access.
- Evidence includes review reports, approvals and removal of inappropriate access.

7. SEGREGATION OF DUTIES (SOD)



- Prevents one person from having conflicting access that could lead to fraud or error.
- Example: The same person should not create payments and approve payments.
- Reduces the risk of unauthorized or inappropriate activities.
- Analysts check role design, access conflicts and review reports.

8. COMMON IAM CONTROLS

Control Area	Examples
User Provisioning	Automated onboarding, role-based access
Access Modification	Change access when roles change
Access Removal	Disable accounts, revoke all access
Authentication	Passwords, MFA, single sign-on (SSO)
Authorization	Role-based access control (RBAC)
Privileged Access	PAM, approval workflow, session recording
Access Reviews	Periodic review and certification
Monitoring	Log and alert on suspicious access
Segregation of Duties	Prevent conflicting roles and access

9. EVIDENCE A GRC ANALYST MAY REQUEST



- User access listings (current and historical)
- Joiner, mover, leaver records
- Access review reports and approvals
- MFA enforcement reports
- Privileged access logs and session recordings
- Role definitions and role-to-permission mappings
- Evidence of access removal for leavers
- SOD analysis and conflict reports
- IAM policies, procedures and screenshots
- System logs showing access changes

10. COMMON MISTAKES



- Giving excessive access.
- Not removing access for leavers.
- Skipping regular access reviews.
- No MFA for privileged accounts.
- Poor role design leading to SOD conflicts.
- Inadequate evidence to prove controls work.

11. KEY TAKEAWAYS



- Manage the full identity lifecycle (joiners, movers, leavers).
- Apply least privilege.
- Use MFA for all users, especially privileged accounts.
- Conduct regular access reviews.
- Enforce segregation of duties.
- Maintain clear evidence to show access control is working.

CHANGE MANAGEMENT

Why organizations control production changes. Requests, approvals, testing, segregation of duties, deployment evidence, emergency changes, and rollback.

1. WHAT IS CHANGE MANAGEMENT?



- A formal process to plan, review, approve, test and implement changes to systems and infrastructure.
- Helps reduce risk, prevent outages, and maintain stability, security and compliance.
- Ensures changes are controlled, documented and can be traced.

2. WHY ORGANIZATIONS CONTROL CHANGES



- Reduces the risk of system failures and downtime.
- Prevents unauthorized or malicious changes.
- Ensures changes are tested and safe.
- Maintains compliance with internal policies and external regulations.
- Provides accountability and audit trail.

3. THE CHANGE LIFECYCLE

- | | | |
|---|-------------------|--|
| 1 | Request | Raise a change request with details and justification. |
| 2 | Review & Approval | Reviewed by relevant stakeholders and approved. |
| 3 | Testing | Test in a non-production environment. |
| 4 | Implementation | Deploy to production as per approved plan. |
| 5 | Verification | Confirm the change worked as expected. |
| 6 | Closure | Document evidence and formally close. |

4. CHANGE REQUEST



- Includes a clear description of the change.
- Business justification.
- Impact assessment.
- Planned implementation date and time.
- Rollback plan.
- Required approvals.

5. APPROVALS AND ROLES



- Approved by the right people (e.g., change manager, system owner, security, business owner).
- Segregation of duties (SoD) ensures the person requesting the change is not the same person approving or implementing it.
- High-risk changes may require additional approvals.

6. TESTING



- Test the change in a development or staging environment.
- Verify functionality, performance and security.
- Use test cases and document results.
- Obtain sign-off before moving to production.

7. DEPLOYMENT EVIDENCE



- Change implementation logs.
- Screenshots of successful deployment.
- System or application logs.
- Deployment pipeline records (e.g., CI/CD).
- Confirmation from the system owner.

8. EMERGENCY CHANGES



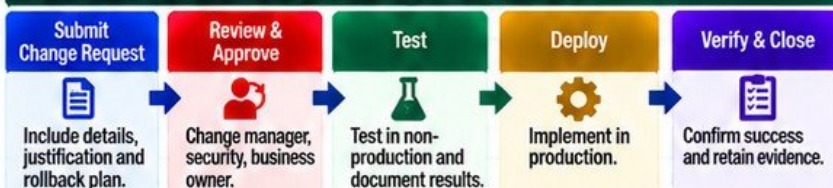
- Used for urgent issues (e.g., security incident, major outage).
- Follow a simplified approval process.
- Must still be documented, reviewed after implementation and include evidence.
- Should be clearly identified as an emergency change.

9. ROLLBACK



- A pre-defined plan to return to the previous state if the change fails.
- Rollback plan should be prepared and tested in advance.
- Evidence of rollback execution should be retained.
- Helps minimize downtime and reduce impact.

10. EXAMPLE: CHANGE REQUEST WORKFLOW



12. KEY TAKEAWAYS



- ✓ Change management reduces risk and ensures system stability.
- ✓ Follow a formal process: request, approve, test, implement, verify, close.
- ✓ Use segregation of duties to prevent unauthorized changes.
- ✓ Always have a rollback plan.
- ✓ Keep clear evidence for audit and compliance.
- ✓ Even emergency changes must be documented and reviewed.

11. COMMON MISTAKES



- Making changes without approval.
- Poor or no testing.
- No rollback plan.
- Inadequate documentation.
- Same person requesting, approving and implementing.
- Not capturing deployment evidence.
- Ignoring post-implementation review.

THIRD-PARTY RISK

How organizations assess vendors, questionnaires, security documentation, contracts, SOC reports, findings, risk ratings, and ongoing monitoring.

1. WHAT IS THIRD-PARTY RISK?



- Risk that comes from vendors, suppliers and service providers.
- Includes cloud providers, SaaS tools, IT vendors, contractors and business partners.
- Can impact security, privacy, operations, finances and reputation.
- Must be assessed and monitored throughout the relationship.

2. THIRD-PARTY RISK LIFECYCLE

1		Identify	Find and categorize third parties.
2		Assess	Evaluate risk using questionnaires and documentation.
3		Analyze	Review findings and assign a risk rating.
4		Contract	Include security requirements in contracts and agreements.
5		Monitor	Continuously monitor performance and risk.
6		Reassess	Reassess regularly or when significant changes occur.

3. COMMON VENDOR TYPES

	Cloud Providers	e.g., AWS, Azure, Google Cloud
	SaaS Providers	e.g., Microsoft 365, Salesforce
	IT Service Providers	e.g., Managed Service Providers (MSPs)
	Professional Services	e.g., Consultants, System Integrators
	Business Process Providers	e.g., Payroll, Customer Support
	Other Suppliers	e.g., Hardware, Facilities, Logistics

4. QUESTIONNAIRES



- Used to collect information about the vendor's security practices.
- Can be a standard questionnaire (e.g., SIG, CAIQ) or a custom one.
- Covers areas such as access control, data protection, incident response, BCP/DR, and compliance.
- Vendor responses must be reviewed and validated.

5. KEY SECURITY DOCUMENTATION



- Information security policies
- Data protection and privacy policies
- Business continuity and disaster recovery plans
- Incident response plan
- Network and infrastructure diagrams (if required)
- Employee security training records
- Penetration test reports (if available)
- SOC reports (e.g., SOC 1, SOC 2)
- Certifications (e.g., ISO 27001)

6. CONTRACTS AND AGREEMENTS



- Include clear security requirements.
- Define data ownership, confidentiality and use.
- Set expectations for incident notification.
- Include right to audit or request evidence.
- Specify compliance requirements (e.g., GDPR, HIPAA, PCI DSS).

7. SOC REPORTS



- SOC 1: Focuses on financial reporting controls.
- SOC 2: Focuses on security, availability, processing integrity, confidentiality and privacy.
- Review the report, management response and auditor's opinion.
- Check the reporting period and scope.
- Identify any exceptions or findings.

8. FINDINGS AND RISK RATING

Risk Rating	Description	Typical Action
High	Significant risk that needs immediate attention.	Mitigate quickly, may require additional controls or delay onboarding.
Medium	Moderate risk that needs to be managed.	Implement action plan with defined timeline.
Low	Minimal risk with acceptable controls.	Monitor and review periodically.

9. ONGOING MONITORING



- Regularly review vendor performance and security posture.
- Monitor for changes in risk (e.g., new services, acquisitions).
- Use automated tools where possible (e.g., security ratings, threat intelligence).
- Reassess high-risk vendors more frequently.
- Ensure issues and findings are tracked to resolution.

10. COMMON MISTAKES



- Relying only on the questionnaire.
- Not reviewing SOC reports properly.
- Missing critical contract clauses.
- Not monitoring vendors after onboarding.
- Ignoring findings or accepting high risk without a plan.
- Not reassessing when the vendor's services change.

11. KEY TAKEAWAYS



- Third-party risk can impact your entire organization.
- Use a structured process: identify, assess, contract, monitor, reassess.
- Request and review key documents, including SOC reports.
- Assign a clear risk rating and track findings.
- Include strong security requirements in contracts.
- Monitor vendors continuously and reassess regularly.

AUDIT FROM THE JUNIOR ANALYST'S DESK

Scope → Request List → Evidence → Testing → Exceptions → Findings →
Management Response → Remediation.
Clarifies auditor versus GRC responsibilities.

1. SCOPE	2. REQUEST LIST	3. EVIDENCE	4. TESTING
 - Defines what will be reviewed (systems, processes, locations, time period). - Based on risk, regulatory requirements or client needs. - Agreed with key stakeholders. - GRC analysts help provide background information and documentation.	 - Auditors send a list of documents, reports, settings and evidence needed. - Organized by control or requirement. - GRC analysts collect and coordinate evidence from different teams. - Ensure evidence is complete, accurate and in the right format.	 - Includes policies, procedures, screenshots, logs, reports, tickets, approvals, configurations and more. - Must be relevant, complete and reliable. - GRC analysts validate evidence and maintain a proper record. - Keep evidence organized and easily traceable to each control.	 - Auditors test the evidence to confirm the control is designed correctly and operating effectively. - Includes walkthroughs, sample testing, interviews and system checks. - GRC analysts support by providing additional information and arranging access to people and systems.
5. EXCEPTIONS	6. FINDINGS	7. MANAGEMENT RESPONSE	8. REMEDIATION
 - Identifies where the control is not working as expected. - Could be missing evidence, incorrect configuration, policy not followed, or control failure. - Auditors document the details, impact and root cause. - GRC analysts help investigate and gather additional information.	 - A formal statement of the issue found. - Includes the condition, criteria, cause and impact (often called the 4 C's). - Can be classified by severity (high, medium, low). - GRC analysts review the findings and ensure they are accurate and understood by the business.	 - The responsible business team agrees or disagrees with the finding. - Provides an explanation, corrective actions and a target completion date. - GRC analysts coordinate with stakeholders to ensure a realistic and clear response is provided. - The response is included in the final audit report.	 - The business team implements the agreed corrective actions. - GRC analysts track progress to closure. - Evidence of remediation is collected and verified. - May be re-tested by auditors or reviewed in a follow-up audit.

AUDITOR vs GRC RESPONSIBILITIES		COMMON DOCUMENTS REQUESTED	1. KEY TAKEAWAYS
Auditor (Internal or External) - Plan and define audit scope - Request and test evidence - Identify exceptions and findings - Provide an independent opinion - Report to management or clients	GRC Analyst - Prepare and provide documentation - Coordinate with business teams - Maintain evidence and trackers - Support during testing and interviews - Track findings and remediation - Help improve controls and processes	 - Policies and procedures - Access reviews and user listings - Change management records - System configurations - Audit logs and monitoring reports - Training records - Risk assessments - Contracts and third-party due diligence - Incident and problem management records - Business continuity and disaster recovery plans	 - Understand the full audit process from start to finish. - Keep evidence organized and traceable. - Work closely with stakeholders. - Understand the difference between auditor and GRC roles. - Track findings to ensure remediation is completed. - Use audit insights to improve controls and reduce risk.
 @veriqta	 @veriqta	 @veriqta	 @veriqta
 @veriqta	 @veriqta		

FINDINGS AND REMEDIATION

How to document a finding, distinguish symptoms from root causes, assign owners, track corrective actions, collect closure evidence, and validate remediation.

1. WHAT IS A FINDING?



- A finding is a documented issue where a control is missing, not designed properly, or not working as intended.
- Based on evidence collected during an audit or assessment.
- Includes the impact, root cause and a recommended action to fix the issue.
- Can be classified by severity (e.g., high, medium, low).

2. SYMPTOM vs ROOT CAUSE

SYMPTOM (What you see)



- The visible issue or what is happening.
- Often a result of a deeper problem.
- Describes the effect, not the real reason.

Example Symptom

10 users have excessive admin access.

ROOT CAUSE (Why it happened)



- The underlying reason it happened.
- Fixing the root cause prevents it from happening again.
- Often related to people, processes, technology or governance.

Example Root Cause

No formal access review process and lack of enforcement.

3. FINDING DOCUMENTATION



- Clear and concise title.
- Detailed description of the issue.
- Affected system, process or data.
- Criteria/requirement that was not met (e.g., policy, standard, framework).
- Evidence supporting the finding.
- Impact and risk.
- Root cause.
- Recommended remediation.
- Severity rating (high, medium, low).

4. FINDING SEVERITY

Severity	Description	Examples
High	Significant risk to business objectives, compliance or security.	● Unauthorized access to sensitive data. ● Critical control not operating.
Medium	Moderate risk with limited impact.	● Incomplete access reviews. ● Missing documentation.
Low	Minor risk, does not significantly impact operations.	● Outdated policy. ● Minor procedural gaps.

5. ASSIGN OWNERS



- Assign a clear owner responsible for remediation (e.g., system owner, process owner, department head).
- Ensure the owner has the authority and resources to implement the fix.
- Agree on a realistic target completion date.
- Track ownership in the findings register.

6. TRACK CORRECTIVE ACTIONS



- Document the agreed action plan.
- Include specific tasks, responsible owner and target dates.
- Track progress regularly (e.g., open, in progress, completed, overdue).
- Escalate overdue items to management.
- Keep the status updated with evidence of progress.

7. COLLECT CLOSURE EVIDENCE



- Evidence must prove the issue has been fixed.
- Examples: updated configuration screenshots, new policies, access lists, training records, change logs, approval records.
- Evidence should be complete, accurate and date stamped.
- Keep evidence organized and linked to the finding.

8. VALIDATE REMEDIATION



- Review the closure evidence to confirm the action was fully implemented.
- Test the control if possible (e.g., sample testing, system checks).
- Ensure the root cause has been addressed, not just the symptom.
- Update the finding status to 'Closed' only when satisfied.

9. FINDING LIFECYCLE

1	Identify	Issue found during audit or assessment.
2	Document	Record details, evidence and root cause.
3	Assign	Assign owner and target date.
4	Remediate	Implement corrective actions.
5	Validate	Review and test evidence.
6	Close	Confirm closure and update status.

10. COMMON MISTAKES



- Describing symptoms instead of root causes.
- Vague or unclear findings.
- Missing or weak evidence.
- No clear owner or target date.
- Not tracking progress regularly.
- Accepting closure without proper validation.
- Reopening findings due to incomplete fixes.

11. KEY TAKEAWAYS



- A finding should be clear, evidence-based and linked to a requirement.
- Always identify and address the root cause.
- Assign the right owner and track corrective actions to completion.
- Collect strong closure evidence and validate the fix.
- Keep the findings register updated with accurate status.
- Effective remediation reduces risk and improves overall control maturity.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta

YOUR FIRST GRC INVESTIGATION

Scenario: A terminated employee still has access. Learner identifies the risk, failed control, evidence required, stakeholders, remediation, and verification.

1. SCENARIO



A former employee was terminated 2 weeks ago, but recently their account was still active and able to access company systems (email, VPN and a key application).

2. IDENTIFY THE RISK



- Unauthorized access to sensitive data.
- Potential data theft or sabotage.
- Reputational damage.
- Regulatory and compliance violations (e.g., GDPR, HIPAA, PCI DSS).

3. FAILED CONTROL



- Offboarding process did not fully remove access in a timely manner.
- Lack of proper access review.
- Breakdown in joiner, leaver process.
- Inadequate monitoring and alerting.

4. EVIDENCE REQUIRED



- Termination/HR record with date and time.
- User account status and access logs (e.g., Active Directory, SSO, VPN, application logs).
- List of systems the user could access.
- Change or offboarding ticket.
- Approval records.
- Email communication between HR, IT and management.
- Any activity performed by the user after the termination date.

5. KEY STAKEHOLDERS



- HR (termination confirmation).
- IT / IAM team (account management).
- System owners (application access).
- Security team (investigation and monitoring).
- Legal / Compliance (regulatory implications).
- Management (escalation and decision making).

6. ANALYSIS QUESTIONS



- When was the employee terminated?
- Which systems did they still have access to?
- What activity (if any) did they perform after termination?
- Why was the access not removed?
- Which control failed?
- Is this an isolated case or part of a larger issue?

7. REMEDIATION ACTIONS



- Immediately disable all accounts and access.
- Enforce the offboarding process for all future terminations.
- Review and update access control procedures.
- Conduct a full access review to identify other orphaned accounts.
- Implement automated offboarding where possible.
- Provide additional training to HR and IT on the process.

8. VERIFICATION



- Confirm the account is disabled in all systems.
- Review logs to ensure no further access.
- Validate with system owners.
- Test the user cannot log in (e.g., VPN, email, applications).
- Document evidence of the remediation.
- Include results in the final report.

9. LESSONS LEARNED



- Timely offboarding is critical.
- Regular access reviews help identify orphaned accounts.
- Automation reduces human error.
- Monitoring and alerts can detect unusual activity early.
- Clear ownership and accountability prevent gaps.

10. EXAMPLE INVESTIGATION FLOW



11. KEY TAKEAWAYS



- Always verify offboarding is completed.
- Access reviews are essential.
- Collect complete and accurate evidence.
- Work with the right stakeholders.
- Document everything.
- Validate the fix, not just the action.
- Use this investigation to identify process improvements.

JUNIOR GRC ANALYST WORKDAY

A realistic workflow combining risk register updates, evidence requests, access-review follow-up, vendor assessment, audit requests, remediation tracking, and escalation.

1. START OF DAY

8:00 – 9:00 AM



- Check emails and priorities.
- Review action items and deadlines.
- Check open audit requests and pending evidence.
- Review risk register updates.
- Attend team stand-up (if applicable).

2. RISK REGISTER UPDATES

9:00 – 10:00 AM



- Update risk status and owner.
- Review new risks and changes in business environment.
- Track risk treatment progress.
- Ensure risks are linked to controls and compliance requirements.

3. EVIDENCE REQUESTS

10:00 – 11:00 AM



- Send evidence requests to system owners.
- Provide clear deadlines and requirements.
- Follow up on outstanding evidence.
- Review received evidence for completeness and quality.

4. ACCESS-REVIEW FOLLOW-UP

11:00 AM – 12:00 PM



- Monitor access review progress.
- Follow up with managers on pending certifications.
- Investigate any unusual or high-risk access.
- Escalate overdue access reviews.

5. VENDOR ASSESSMENT

1:00 – 2:00 PM



- Review vendor questionnaires.
- Collect and evaluate security documentation (e.g., SOC reports, policies, certifications).
- Assess risk and assign a rating.
- Identify gaps and request additional information.
- Track remediation for high-risk vendors.

6. AUDIT REQUESTS

2:00 – 3:00 PM



- Support internal or external audit requests.
- Gather and organize evidence for auditors.
- Answer auditor questions and provide clarifications.
- Track open items and ensure timely closure.

7. REMEDIATION TRACKING

3:00 – 4:00 PM



- Review open findings and remediation plans.
- Check progress with control owners.
- Update status and target dates.
- Follow up on overdue actions.
- Validate closure evidence when provided.

8. ESCALATION AND COMMUNICATION

4:00 – 4:30 PM



- Escalate overdue items or high-risk issues.
- Communicate with key stakeholders (IT, security, business owners, management).
- Provide status updates.
- Highlight risks and issues that need management attention.

9. END OF DAY

4:30 – 5:00 PM



- Update task list and track completed work.
- Prepare for next day.
- Document key discussions and decisions.
- Ensure all follow-ups and reminders are set.
- Keep records organized in your GRC tool or tracker.

10. EXAMPLE DAILY TASK LIST

- ✓ Update risk register (3 risks).
- ✓ Send 5 evidence requests.
- ✓ Follow up on 2 access reviews.
- ✓ Review 1 vendor questionnaire.
- ✓ Prepare documentation for ongoing audit.
- ✓ Update 3 remediation actions.
- ✓ Escalate 1 overdue item.
- ✓ Attend team meeting.
- ✓ Document key notes and next steps.

11. KEY SKILLS USED



Attention to detail



Communication



Documentation



Stakeholder management



Time management



Problem solving



Risk and compliance knowledge



Familiarity with tools (e.g., GRC platforms, Excel)

12. KEY TAKEAWAYS



- ✓ Stay organized and track your tasks.
- ✓ Meet deadlines and follow up.
- ✓ Ensure evidence is complete and accurate.
- ✓ Proactively manage risks and remediation.
- ✓ Communicate clearly with stakeholders.
- ✓ Escalate issues when needed.
- ✓ Build strong documentation habits.
- ✓ Consistency and follow-through are essential.



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta



@veriqta